

March 15, 2025

To: Networking and Information Technology Research and Development (NITRD) National Coordination Office (NCO), National Science Foundation, OSTP.

Via: [REDACTED]

OpenPolicy's comment on
The Networking and Information Technology Research and Development (NITRD) National Coordination Office (NCO)'s Request for Information on the Development of an Artificial Intelligence (AI) Action Plan

Introduction

OpenPolicy appreciates the opportunity to provide input on the development of the national AI Action Plan. As a technology policy organization dedicated to democratizing access to policy for innovators and startups, OpenPolicy leverages AI and automation to help companies of all sizes engage with the government on critical issues and matters of Cybersecurity, AI, and defense policy. We are deeply committed to fostering open, collaborative policymaking that balances security and innovation. Our mission is to support the ability of innovative leaders in the policy-making process— to assist the evolving AI and cybersecurity policy landscape. Such perspectives help ensure that advances in Artificial Intelligence (AI) are deployed responsibly and resilient. We strongly support the Plan's objective of sustaining American leadership in AI while promoting secure, trustworthy, and resilient AI development and use — without imposing unnecessary burdens on innovation.

These comments are submitted on behalf of OpenPolicy's **innovative cybersecurity and AI ecosystem**, focusing on key AI security challenges and priorities identified in the RFI. We believe that an open dialogue— engaging government, industry, and civil society— is essential to crafting policies that foster AI innovation and safeguard our digital ecosystem. The participation of **startups, innovators, and cutting-edge solution** providers at the forefront of AI and cybersecurity is particularly critical, as they are pioneering many of the tools and practices needed for effective AI risk management.

In line with our previous regulatory submissions and building on our active participation in the Artificial Intelligence Safety Institute Consortium (AISIC), and our

robust engagement with NIST and Congress, we offer the following comments focused on key areas of AI security, safety, and governance. We stand ready to assist in implementing these recommendations and to continue engaging with policymakers to promote innovative, responsible, and scalable AI development.

Enhancing Governance, Risk Management, and Ecosystem Security for AI Systems in Complex Environments

To support the responsible deployment of AI technologies, OpenPolicy recommends that the AI Action Plan adopt a comprehensive framework that bolsters standards and guidelines that address governance, risk management, model security, and innovation. As AI ecosystems expand across interconnected Software-as-a-Service (SaaS) environments, industrial control systems, Internet of Things (IoT) networks, and Low-Code/No-Code (LCNC) platforms – these evolving digital landscapes demand adaptive security strategies that account for new risks. Ensuring the security and resilience of AI systems requires a governance framework that reflects the complex environments in which these systems increasingly operate.

Establishing a **risk-based, scalable approach to AI governance** is essential to ensure AI systems are deployed securely while maximizing their transformative potential. OpenPolicy strongly encourages leveraging **automated security frameworks**, integrating real-time threat detection, security audits, and continuous risk assessments throughout the AI lifecycle – and frameworks that also consider the risks that AI introduces to the systems in which they are deployed. These automated solutions are critical for identifying and mitigating emerging risks such as **adversarial manipulation, model drift, and data poisoning**. By integrating these frameworks into existing enterprise security workflows, organizations can improve adaptability and ensure that security practices scale alongside AI adoption.

Automated governance tools are also vital for improving oversight by enabling efficient documentation management, audit tracking, and real-time detection of deviations. These capabilities help reduce human error while ensuring that security gaps are promptly identified and addressed. To further strengthen governance practices, OpenPolicy emphasizes that automated risk assessment tools must include **dynamic risk scoring** and **adaptive security controls** that adjust in real-time to respond to evolving threat conditions. AI-driven governance solutions should continuously assess model behavior, refine risk policies based on emerging adversarial techniques, and enforce security controls accordingly.

Additionally, governance solutions must incorporate **provenance tracking** to provide organizations with clear visibility into data sources, model updates, and dependencies across the AI development lifecycle. Provenance tracking is essential for maintaining data integrity, detecting data poisoning attempts, and ensuring AI systems are not influenced by tampered or malicious data inputs. This visibility also supports organizations in monitoring model performance over time, ensuring that evolving conditions or data changes do not degrade system accuracy or introduce bias.

AI security must address not only individual models and datasets but also the broader systems in which they operate. As AI technologies become deeply integrated into complex environments such as government systems and critical infrastructure, the risks associated with interconnected components and services increase significantly. The AI Action Plan should promote comprehensive security practices that ensure continuous visibility into the full AI ecosystem, including AI models, training data, APIs, and third-party services. Achieving this requires **technical verification** across the entire AI development lifecycle to ensure that AI assets are rigorously evaluated for vulnerabilities and weaknesses before deployment and continuously monitored throughout their operational use.

In parallel with model security, the AI Action Plan should address the rising risks associated with **non-human identities (NHIs)** and **shadow AI** systems. NHIs, such as machine-to-machine accounts, API keys, and service tokens, are essential for connecting AI services, yet they frequently operate without sufficient oversight. These identities often maintain extensive system access, making them attractive targets for adversaries. Recent incidents, such as the Midnight Blizzard¹ attack targeting Microsoft's corporate environment and the U.S. Treasury breach² via compromised API keys, highlight how poorly managed NHIs can provide attackers with an entry point to critical systems.

Similarly, **shadow AI** systems— AI tools or models adopted without formal IT approval— expand the attack surface by circumventing traditional security controls. These unsanctioned systems often integrate with sensitive data sources and lack proper monitoring, increasing the risk of data exfiltration, manipulation, or disruption. To mitigate these risks, OpenPolicy strongly recommends that the AI

¹See Dark Reading article on "Microsoft Shares New Guidance in Wake of 'Midnight Blizzard' Cyberattack" <https://shorturl.at/4POuU>

²See Dark Reading article on "Chinese State Hackers Breach US Treasury Department" <https://shorturl.at/1ol5W>

Action Plan promote continuous discovery and inventory management solutions that map OAuth tokens, API connections, and machine-to-machine links. These automated tools provide security teams with full visibility into AI services, NHIs, and third-party integrations, allowing them to detect overly permissive configurations, suspicious connections, or unauthorized behavior before attackers exploit these vulnerabilities.

The complexity of modern AI environments is further compounded by the rapid proliferation of **IoT (Internet of Things)** and **OT (Operational Technology)** systems. These devices are now frequently integrated with AI technologies to enable automated control, enhance decision-making, and improve efficiency. However, IoT/OT devices are often deployed without built-in security controls, making them vulnerable to compromise. As adversaries increasingly target these environments, organizations risk operational disruption, data manipulation, or malicious system control if appropriate safeguards are not in place.

Given the constraints of IoT/OT environments — where active scanning may disrupt essential processes — OpenPolicy recommends that the AI Action Plan emphasize **passive monitoring techniques** to identify unmanaged or legacy devices that may lack security protections. Passive monitoring provides non-intrusive visibility into device activity, supporting comprehensive asset inventories that account for both modern and legacy infrastructure. To enhance security further, OpenPolicy emphasizes the importance of **AI-driven behavioral analysis models** for detecting deviations from baseline behavior. Such models can identify compromised IoT/OT devices, unauthorized configuration changes, or attempts to manipulate AI-enabled control systems. By establishing behavioral baselines and identifying deviations in real-time, organizations can mitigate attacks that exploit vulnerable IoT/OT assets.

The use of **collective intelligence models** can further enhance the security of AI-integrated IoT/OT ecosystems. Given that adversaries often exploit weakly secured devices across multiple organizations, collaborative threat intelligence enables faster identification of attack patterns and shared mitigation strategies. For example, platforms that aggregate insights from various device profiles can rapidly alert organizations when new threats targeting similar devices emerge. By adopting collective threat intelligence approaches, organizations can strengthen their resilience to AI-driven attacks that leverage vulnerabilities in IoT/OT environments.

In parallel, OpenPolicy emphasizes the need to address risks emerging from the rapid adoption of **Low-Code/No-Code (LCNC)** platforms and **AI Agents**. LCNC

platforms empower non-technical users to build AI applications and autonomous agents with minimal coding expertise. While these platforms accelerate innovation, they frequently bypass traditional IT oversight, creating serious security risks. AI Agents built-in LCNC environments often operate autonomously, continuously evolving post-deployment while interacting with sensitive data and enterprise systems. Without proper governance, these agents can unintentionally expose sensitive information, execute unauthorized transactions, or become vulnerable to **prompt injection attacks, data exfiltration, or manipulative prompts** that alter their intended behavior.

To mitigate these risks, OpenPolicy strongly recommends that the AI Action Plan promote the development and adoption of standards related to automated discovery and inventory management tools designed to identify LCNC-built AI agents and track their configurations, permissions, and interactions with enterprise systems. Continuous monitoring solutions should assess AI agent behaviors, identify excessive permissions, and flag suspicious activities such as unexpected data transfers, anomalous model responses, or unauthorized changes to prompts. We recommend that the AI Action Plan also emphasize the development of **adaptive security controls** for LCNC and AI Agent environments. These controls should integrate **contextual threat analysis, event-driven monitoring, and user behavior tracking** to detect and respond to suspicious activity in real-time. Implementing such adaptive controls will enable organizations to dynamically adjust access permissions, contain compromised agents, and prevent malicious manipulation of AI outputs.

The AI Action Plan could also address the need for security teams and AI developers to collaborate closely to safeguard sensitive data and prevent unintended exposure. Given the rapid adoption of AI tools and services, it is essential that organizations establish proactive risk assessment frameworks that continuously evaluate AI components for security gaps. Implementing clear processes that connect AI developers and security teams will help maintain visibility into architecture, tooling, and model behaviors, ensuring that security concerns are addressed before vulnerabilities are exploited. By promoting these strategies — including automated risk assessment, dynamic security controls, proactive collaboration, and continuous monitoring — the AI Action Plan can provide organizations with the tools needed to deploy AI securely while maximizing innovation.

Strengthening AI Red-Teaming, Adversarial Testing, and GenAI Security

In addition to governance and visibility, OpenPolicy recommends the AI Action Plan to institutionalize **AI red-teaming** as a foundational security practice. **Proactive adversarial testing** is essential to identifying vulnerabilities before they are exploited in real-world scenarios. AI models are increasingly targeted by threat actors employing sophisticated tactics such as prompt injection attacks, model inversion exploits, and adversarial manipulation techniques designed to bypass traditional defenses. Red-teaming should not be treated as a one-time evaluation but rather as a **continuous process** applied throughout an AI system's development, deployment, and maintenance. This ongoing practice will ensure AI models remain **resilient** as adversaries evolve their **attack strategies**.

To enhance AI red-teaming efforts, the AI Action Plan should promote frameworks that standardize adversarial testing methodologies, ensuring organizations apply consistent approaches to identifying AI-specific risks. In particular, red-teaming strategies should address both **technical weaknesses** within models and operational vulnerabilities that arise from AI system integration. **Combining automated adversarial tools** with skilled human testers will further strengthen these efforts. While automated systems can efficiently identify known attack patterns, expert testers are better equipped to uncover nuanced and context-specific weaknesses that automated tools may overlook. This hybrid strategy is especially important in identifying complex manipulation attempts, such as AI-generated misinformation or adversarially distorted media.

A comprehensive red-teaming framework must extend beyond technical vulnerabilities to address **AI-driven social engineering attacks** and broader AI risks, such as bias and misalignment between model outcomes and intended goals. Attackers may attempt to manipulate AI systems directly — for example, by submitting specially crafted inputs to an AI chatbot to extract confidential information or by exploiting AI-driven customer service tools using tactics like deepfake audio in vishing (voice phishing) attacks. To mitigate these risks, we recommend that organizations conduct regular red-team exercises that simulate both **adversarial scenarios** and **AI-induced crises**, ensuring that testing strategies address **technical weaknesses**, **operational vulnerabilities**, and broader risks. Establishing AI-specific red-teaming frameworks that distinguish between these risks will ensure organizations adopt tailored approaches that account for both **technical** and **non-technical vulnerabilities**, strengthening overall **AI system resilience**.

The AI Action Plan should further encourage improved **risk-based vulnerability management** practices. As organizations increasingly rely on **open-source AI libraries**, the pace of **vulnerability discovery** often overwhelms security teams. Conventional vulnerability management practices that emphasize vulnerability counts alone fail to account for real-world exploitability, which can result in organizations expending resources on low-risk issues while overlooking genuine threats. Solutions that apply contextual risk intelligence address this challenge by correlating vulnerability data with usage context, exploitability, and threat intelligence. For instance, a vulnerability in a widely used AI library may present minimal risks if the vulnerable code path is never executed in deployed systems. By integrating **risk-based vulnerability management** techniques into its guidance, the AI Action Plan can encourage organizations to prioritize vulnerabilities that present tangible security risks. Encouraging security teams to apply AI-driven analysis tools that assess exploitability and real-world risk will help organizations strengthen their security posture while optimizing resource allocation.

Further strengthening these efforts, the AI Action Plan should encourage **automated remediation workflows** integrated into CI/CD pipelines to improve response times and reduce exposure windows. By leveraging **automated remediation platforms**, which generate pull requests and code fixes automatically, organizations can have an effective model for accelerating the remediation process. Encouraging automated remediation will promote proactive security measures that mitigate AI risks swiftly and efficiently.

The emergence of **Generative AI (GenAI)** adds further complexity to the cybersecurity landscape. While GenAI tools offer immense potential to improve productivity, they also pose significant security risks. Large Language Models (LLMs), in particular, introduce risks related to misinformation, data leakage, and adversarial manipulation. Without proper safeguards, organizations risk inadvertently sharing sensitive information or relying on GenAI-generated insights that may be biased, inaccurate, or compromised. To address these risks, the AI Action Plan should include guidance on securing GenAI tools and mitigating **LLM-related vulnerabilities**. Incorporating best practices from established AI governance frameworks will further strengthen the security of GenAI systems.

Finally, OpenPolicy urges the AI Action Plan to promote stronger incentives for public and private sector organizations to conduct responsible vulnerability **disclosure programs, establish bias bounties, and publish AI assurance reports.**

By encouraging greater transparency through structured disclosure mechanisms, organizations can accelerate the identification of emerging threats and foster greater public trust in AI systems.

Enhancing Real-Time Monitoring and Incident Response

Recognizing that preventive security measures alone are insufficient, OpenPolicy further recommends that the AI Action Plan promote **real-time monitoring systems to detect and respond to AI misuse, exploitation, and manipulation**. Continuous monitoring capabilities are critical for identifying deviations in AI model behavior that may signal adversarial manipulation, compromised datasets, or system failures. Adaptive monitoring solutions that apply machine learning to track model behavior can rapidly identify suspicious activity and trigger automated incident response protocols. For instance, anomalous patterns in a model's outputs — such as a language model producing inappropriate content or a vision system misclassifying objects in unpredictable ways — may indicate adversarial interference that requires immediate intervention.

The Plan should encourage organizations to adopt real-time monitoring systems that combine behavioral analysis, contextual threat detection, and automated incident response protocols. Automated alerts triggered by unusual behavior patterns — such as a language model generating unexpected content, AI agents, or an AI vision system misclassifying objects in unpredictable ways — allow organizations to intervene swiftly and mitigate potential harm. By integrating these monitoring tools with established **incident response frameworks**, organizations can reduce the impact of AI misuse and improve overall system resilience. Establishing a formal mechanism for sharing threat intelligence between AI developers, cloud providers, and security researchers can further strengthen early detection capabilities and improve coordinated responses to adversarial AI threats.

In addition to technical safeguards, organizations should adopt structured incident response plans tailored to AI-specific threats. OpenPolicy encourages the AI Action Plan to promote the development of incident response playbooks that define escalation protocols and containment strategies, as well as model rollback procedures to mitigate risks. These playbooks should align with broader cybersecurity response frameworks to ensure rapid containment of AI-related security incidents. Establishing a formal mechanism for sharing threat intelligence between AI developers, cloud providers, and security researchers can further strengthen early detection capabilities and improve coordinated responses to

adversarial AI threats.

Improving Content Provenance, Supply Chain Security, and Cloud Adoption

Ensuring the authenticity and traceability of AI-generated content is equally critical to maintaining public trust in AI technologies. OpenPolicy recommends that the AI Action Plan emphasize content provenance solutions that authenticate **AI-generated outputs** using cryptographic signatures, metadata labeling, and watermarking. These techniques are crucial for verifying content origin, detecting manipulation, and improving accountability in sensitive environments where trust is essential. The AI Action Plan should also encourage investment in AI explainability techniques to ensure that organizations can provide clear, interpretable insights into how AI models generate decisions, supporting responsible use in high-stakes applications such as healthcare, finance, and law enforcement.

Securing the **AI supply chain** is equally vital to protecting AI models from manipulation or compromise. AI systems increasingly rely on third-party datasets, pre-trained models, and API integrations, creating an expanded attack surface that adversaries can exploit. OpenPolicy recommends that the AI Action Plan encourage comprehensive AI supply chain security practices, including **verifying the integrity of third-party components, tracking dependencies, and assessing AI model artifacts for security weaknesses**. Automated dependency-tracking tools can help organizations proactively identify risks such as poisoned datasets, tampered model weights, and compromised APIs. Additionally, organizations should implement structured risk assessment processes that assess the security posture of AI vendors and partners to minimize risks throughout the development and deployment lifecycle.

OpenPolicy further recommends that the AI Action Plan **prioritize modernizing federal systems** by promoting secure cloud adoption. **Cloud environments** provide enhanced manageability, increased observability, and improved documentation capabilities that support secure AI deployments. By transitioning legacy on-premise systems to modern cloud infrastructure, federal agencies can leverage scalable security controls, adaptive risk management tools, and improved visibility into AI system behaviors. The Plan should encourage agencies to prioritize secure cloud frameworks that support continuous monitoring, zero-trust access controls, and automated policy enforcement.

Advancing Encryption-in-Use and Zero Trust Solutions to Safeguard Sensitive

Information in AI Ecosystems

As AI technologies increasingly rely on vast amounts of sensitive data to train, validate, and refine their models, traditional data security measures are proving insufficient to mitigate emerging risks. While encrypting data at rest and in transit remains an essential security practice, these controls fail to address a crucial gap: the protection of data during active computation — often referred to as the "data-in-use" phase. This gap presents significant exposure risks, particularly in AI environments where large volumes of data are aggregated for model training, real-time analytics, or inference.

Threat actors are increasingly exploiting this vulnerability, recognizing that sensitive information processed in **plaintext during computation is susceptible to interception, manipulation, or exfiltration**. This risk is compounded in AI ecosystems that rely on distributed cloud environments, decentralized data pipelines, and real-time data exchanges, all creating dynamic attack surfaces that traditional security models may fail to address. Addressing this data-in-use risk is paramount to building secure AI ecosystems.

Technologies that enable **encryption-in-use** offer automated solutions to mitigate this gap, allowing data to remain encrypted while being processed, analyzed, or leveraged for AI-driven computations. Solutions that leverage advanced cryptographic methods— **including homomorphic encryption and secure multiparty computation**— enable secure data processing without requiring decryption. By maintaining encryption throughout the data lifecycle, encryption-in-use technologies effectively neutralize the risks tied to plaintext exposure, reducing potential attack surfaces even in the event of a system compromise. This capability is particularly vital in **high-risk AI environments** that handle sensitive financial data, regulated health information, or intellectual property.

Beyond addressing data-in-use vulnerabilities, strengthening **data-centric security controls** is crucial for ensuring that sensitive information is adequately protected throughout the AI lifecycle. As AI systems routinely interact with proprietary data, personal information, and other high-value data assets, these interactions create new avenues for adversarial threats, data leakage, and unauthorized access. To mitigate these risks, organizations must adopt security solutions that enforce robust governance and apply **Zero Trust principles** directly to content flows.

Private Data Network (PDN) consolidates sensitive content communications into a secure, controlled environment by deploying content firewalls that inspect and authorize all incoming and outgoing data exchanges, ensuring that no file or message enters or leaves an organization's infrastructure without thorough validation. This proactive approach enforces Zero Trust principles by ensuring that all content flows are verified, logged, and protected.

To further reduce data exposure risks, organizations should implement robust controls that restrict data exchanges between enterprise repositories and AI systems. This can be achieved through content type filtering, trusted channel verification, and secure data gateways. By enforcing governance policies, applying **Zero Trust safeguards, and maintaining comprehensive audit trails**, these practices ensure that only authorized data moves through approved channels. Such measures are particularly valuable in AI environments where sensitive data — including healthcare records, financial information, and other regulated content — must be securely processed while maintaining compliance with frameworks like GDPR, HIPAA, and emerging AI-specific regulations.

AI systems also present **dual-use potential**, where adversaries can exploit AI to develop sophisticated attack techniques while organizations simultaneously leverage AI to enhance their cybersecurity defenses. As attackers increasingly use AI to automate reconnaissance, craft realistic phishing content, and evade traditional security controls, organizations must adopt **AI-driven capabilities to counter these evolving threats**. AI-enhanced content analytics solutions improve threat detection by analyzing content flows for anomalous behaviors that may indicate data manipulation, exfiltration attempts, or compromised repositories. By identifying emerging risks in real-time, these AI-enhanced solutions enable organizations to adopt proactive defenses against adversarial AI threats.

Given that AI systems frequently process regulated and personally identifiable information (PII), it is also essential to integrate **privacy-centric strategies** into AI security frameworks. Solutions that enforce data sovereignty controls and apply encryption-in-use offer practical safeguards for ensuring data privacy during AI model development and deployment. Furthermore, addressing technologies that provide automated compliance reporting, comprehensive audit trails, and centralized governance tools reinforce **privacy-by-design** principles and enhance **regulatory alignment**. Encouraging the adoption of these capabilities will help organizations secure sensitive data across AI workflows while maintaining visibility

into data-handling practices.

Incorporating these security measures — encryption-in-use technologies, Zero Trust content controls, and AI-driven threat detection — within the AI Action Plan would significantly enhance the security of data exchanges, **mitigate risks stemming from adversarial AI techniques, and ensure compliance with privacy regulations**

As this RFI Implementation evolves, we look forward to discussing these proposals with the department and are available for any questions. We believe that considering relevant taskings for the development of guidelines and standards to address the above emerging areas of threats and risk would bolster the ability of both private and public organizations to adopt AI more swiftly, while limiting risks.

We remain excited to collaborate to increase engagement with innovative companies.

This document is approved for public dissemination. The document contains no business-proprietary or confidential information. Document contents may be reused by the government in developing the AI Action Plan and associated documents without attribution.

Respectively,

/s/ Michelle Sahar

Michelle Sahar

Cybersecurity & AI Policy Director, OpenPolicy

/s/ Dr. Amit Elazari

Amit Elazari

Co-founder and CEO, OpenPolicy